

Production Readiness

This checklist defines the minimum bar before AMW Command is promoted from an internal candidate to a production-grade HR platform.

Release Gates

- `npm run verify` passes locally and in CI.
- Frontend E2E smoke passes on desktop and mobile, including export menu and download flows.
- `npm run test:integration -w backend` passes against a migrated PostgreSQL database.
- Gitleaks secret scan passes in CI.
- Dependabot is enabled for npm and GitHub Actions.
- No high or critical dependency vulnerabilities are accepted without a documented exception.

Environment

- `NODE_ENV=production` .
- `JWT_SECRET` is a random value with at least 32 characters.
- `CORS_ORIGINS` contains only approved production origins.
- `ALLOW_PUBLIC_REGISTRATION=false` unless a controlled onboarding exception is approved.
- `DATABASE_URL` points to a managed PostgreSQL instance with backups enabled.
- `SENTRY_DSN` or an equivalent monitoring sink is configured.
- `frontend/public/fonts/AMW-Report-Regular.ttf` is supplied with an approved Unicode TTF for Thai/French PDF export.

Security

- API responses include no-store cache headers.
- Helmet security headers are enabled.
- Request correlation is enabled through `X-Request-Id` .
- Mutating API requests emit structured audit logs.
- Audit events are persisted in the `AuditEvent` table for login, export, and mutating API activity.
- RBAC integration tests cover admin, manager, and employee paths.
- Export controls preserve role boundaries; employee exports do not include salary data.
- Production SSO should be integrated through Microsoft Entra ID or an equivalent IdP before external rollout; local password auth is acceptable only for controlled internal pilots.
- Frontend sessions expire client-side after 12 hours and server-side JWT expiry must be equal or shorter for production.

Observability

- `/health` is used for liveness.
- `/ready` or `/api/ready` is used for readiness and dependency checks.
- Alerts exist for API 5xx rate, auth failures, DB readiness failure, and latency.
- Logs are searchable by `requestId` , actor, method, path, and status.
- Audit records are searchable by event type, actor, target, and request id.
- Export events alert on unusual volume, repeated failures, or salary-scoped exports outside HR leadership.

Data Protection

- Database backups are encrypted and restore-tested.
- HR records have a documented retention policy.

- Salary and bonus fields are treated as sensitive data.
- Access reviews are scheduled for admin and manager roles.
- PDF exports include classification, document id, watermark, and page footers.

Operations

- Rollback steps are documented before release.
- Database migrations are applied before app rollout.
- A staging deployment mirrors production configuration.
- A restore drill has been completed in the last quarter.